

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 31

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM8-058)

Scenario: A solar-equipment company is adding subscription leasing with remote performance monitoring and customer billing. Its existing program focuses on manufacturing offices.

What should PRIMARILY determine the revised program objectives?

- A. The security products already used in corporate offices
- B. The controls used by one competing manufacturer
- C. The leasing service's business outcomes, information, obligations, dependencies, and risks
- D. The projects requiring the least operational change

Question 2 (CISM8-059)

Scenario: A cooperative network of local lenders shares payment and identity services. Member institutions dispute which security requirements are mandatory and who may approve deviations.

Which governance foundation should be created FIRST?

- A. A detailed product configuration guide
- B. A schedule of audits operated by the payment provider
- C. An approved charter defining shared objectives, authority, scope, responsibilities, sponsorship, and escalation
- D. Separate program objectives for every member

Question 3 (CISM8-060)

Scenario: A telehealth provider acquires several clinics and plans rapid platform integration. Identity onboarding, medical-device inventory, and supplier reviews are scheduled after the integration date.

Which acquisition-roadmap response is MOST appropriate?

- A. Reassess acquisition risks and dependencies, then propose a funded sequence aligned with integration milestones.
- B. Add every acquisition task without changing capacity or funding.
- C. Integrate the clinics first and address program gaps afterward.
- D. Preserve the original dates because approved roadmaps should remain fixed.

Question 4 (CISM8-061)

Scenario: Two airlines share bookings and loyalty benefits under a partnership. Customer data moves through both airlines and several service providers, but no party controls the entire journey.

Which program-scoping approach is BEST?

- A. Include only systems owned by the larger airline.
- B. Assign all customer risk to booking providers.
- C. Exclude loyalty data because it is shared.
- D. Map the end-to-end journey, information flows, obligations, dependencies, risks, and responsibilities at every interface.

Question 5 (CISM8-062)

Which information provides the BEST basis for a control-testing resource plan?

- A. The current number of security employees
- B. A peer organization's assurance headcount
- C. The total pages in the control framework
- D. Control population, risk tiers, test frequency and method, evidence complexity, competencies, and automation

Question 6 (CISM8-063)

Scenario: A global nonprofit needs awareness materials adapted to several languages and cultural contexts. Internal staff understand the target behaviors but lack localization capacity.

Which localization sourcing arrangement is MOST appropriate?

- A. Let a localization provider define program objectives independently.
- B. Use qualified localization support under internal control of objectives, accuracy review, behavior measures, and knowledge transfer.
- C. Delay awareness until internal language specialists are hired.
- D. Use identical untranslated content in every region.

Question 7 (CISM8-064)

Scenario: A publishing company operates many identity services after acquisitions. Consolidation could improve governance, but legacy applications, migration effort, and business disruption are significant.

Which investment analysis is MOST decision-useful?

- A. A comparison based only on feature counts
- B. A business case comparing risk reduction, operating benefits, migration dependencies, business impact, feasibility, and lifecycle cost
- C. Selection of the most visible supplier
- D. A promise that consolidation will eliminate all access risk

Question 8 (CISM8-065)

Scenario: An industrial supplier is moving business platforms to cloud services. Its security team has strong infrastructure operations skills but limited cloud governance and provider-assurance experience.

Which competency action should occur FIRST?

- A. Assign cloud risk acceptance to providers.
- B. Give every employee the same introductory course.
- C. Transfer governance responsibilities to internal audit.
- D. Create a competency plan combining targeted development, recruitment, succession, and selective external expertise.

Question 9 (CISM8-066)

Who should normally determine the classification of a business dataset?

- A. The database administrator
- B. The backup provider
- C. The accountable information owner
- D. The independent auditor

Question 10 (CISM8-067)

Which practice BEST keeps an information asset inventory current?

- A. Embedding ownership, classification, location, and lifecycle updates into application and business change processes
- B. Updating the inventory only before audits
- C. Recording only hardware purchased by technology staff
- D. Assigning all information to the security department

Question 11 (CISM8-068)

Scenario: A consulting firm labels client material as confidential, but employees reuse slides at conferences without consistent review or removal of sensitive content.

Which handling improvement is MOST appropriate?

- A. Remove confidential labels from presentation copies.
- B. Define classification-based review, redaction, approval, display, retention, and disposal rules within the presentation workflow.
- C. Require security to approve every presentation personally.
- D. Count the number of presentations delivered externally.

Question 12 (CISM8-069)

Scenario: A property developer's joint venture ends. Project records remain in shared workspaces, and neither partner has determined which records must be retained, returned, restricted, or destroyed.

Which lifecycle decision should occur FIRST?

- A. Delete all shared records immediately.
- B. Keep every copy indefinitely.
- C. Let workspace administrators decide ownership.
- D. Confirm ownership and requirements before return, retention, and disposal

Question 13 (CISM8-070)

What is the PRIMARY purpose of adopting a security framework?

- A. To provide a structured basis for organizing, assessing, and improving relevant capabilities
- B. To transfer accountability to the framework publisher
- C. To guarantee acceptance of residual risk
- D. To impose identical technologies on every organization

Question 14 (CISM8-071)

Which factor set should guide framework tailoring?

- A. The order in which the framework publishes its sections
- B. The controls already supported by current tools
- C. The preferences of the implementation consultant
- D. Business objectives, risks, obligations, dependencies, and current capability gaps

Question 15 (CISM8-072)

Scenario: A business-processing firm maintains separate control implementations for different customer assurance schedules, although many required outcomes overlap.

Which framework-integration response is MOST appropriate?

- A. Use one customer's schedule for all customers without analysis.
- B. Ignore customer requirements that resemble internal controls.
- C. Build a different control for every requirement sentence.
- D. Map requirements to a governed common control and evidence model while preserving customer-specific traceability.

Question 16 (CISM8-073)

Which security document normally communicates management's mandatory direction and intent?

- A. Policy
- B. Guideline
- C. Procedure
- D. Test plan

Question 17 (CISM8-074)

Which document should describe the ordered steps for revoking a departing employee's access?

- A. Procedure
- B. Standard
- C. Policy
- D. Guideline

Question 18 (CISM8-075)

Scenario: A distribution center cannot apply a new device-control standard to certified scanners until the next maintenance cycle. Operations proposes network isolation and enhanced monitoring.

Which exception conditions should be required before approval?

- A. Permanent exclusion of all certified devices
- B. Documented risk, accountable approval, compensating controls, monitoring, review triggers, and a defined expiration
- C. Approval solely by the scanner operator
- D. Evidence that scanners have not caused a previous incident

Question 19 (CISM8-076)

Scenario: A finance procedure retains customer verification records for seven years, while the approved information standard sets a three-year period for the same records.

Which document-hierarchy response should occur FIRST?

- A. Let employees choose either retention period.
- B. Engage accountable owners to determine applicable requirements, then approve and communicate a consistent retention rule.
- C. Assume the longer period is always safer.
- D. Wait for an audit before resolving the conflict.

Question 20 (CISM8-077)

Scenario: A retailer is replacing a single commerce platform with independently deployable services. Teams are selecting inconsistent identity, secrets, data-protection, and telemetry approaches.

Which security architecture foundation should be defined FIRST?

- A. Security principles and shared capabilities aligned with the target enterprise architecture, business needs, and risks
- B. Detailed configurations for every service
- C. A requirement to purchase one product suite
- D. Permanent permission for teams to use unrelated designs

Question 21 (CISM8-078)

Scenario: A public utility's target architecture requires unified device identity and monitoring. Existing substations use multiple generations of equipment that will be replaced gradually.

Which roadmap element is MOST important?

- A. Only a diagram of the final target state
- B. Immediate replacement regardless of operational impact
- C. A gap and dependency analysis defining transition states, interim controls, accountable owners, and milestones
- D. Permanent target states for each equipment generation

Question 22 (CISM8-079)

Scenario: A legal technology platform must separate confidential matters belonging to different clients. Reviewers cannot determine how the proposed architecture enforces that requirement across shared services.

Which architecture evidence should the manager request?

- A. A list of every device used by the platform
- B. Traceability from the separation requirement to data flows, architecture decisions, control ownership, and acceptance criteria
- C. A statement that shared services are widely used
- D. Transfer of approval authority to the hosting provider

Question 23 (CISM8-080)

Scenario: A critical revenue project cannot use an approved security pattern because of a legacy dependency. The team proposes a local design with no migration date.

Which architecture-governance decision is MOST appropriate?

- A. Reject every deviation regardless of business impact.
- B. Remove the project from architecture governance.
- C. Let the supplier accept the organization's residual risk.
- D. Assess the deviation, approve interim controls, and track convergence

Question 24 (CISM8-081)

Scenario: A global charity can replace regional access services through one cutover or phased migrations. A single cutover reaches consistency faster, while phasing limits program disruption but requires temporary federation.

Which evaluation basis should guide the roadmap choice?

- A. Compare risk reduction, resilience, dependencies, interim controls, operational impact, support capacity, lifecycle cost, and exit criteria.
- B. Choose the fastest option because speed always reduces risk.
- C. Retain regional services indefinitely.
- D. Allow each region to define an unrelated permanent target.

Question 25 (CISM8-082)

Which metric BEST reflects the outcome of a control-assurance capability?

- A. Number of test templates created
- B. Hours spent collecting evidence
- C. Timely sustainable remediation of material deficiencies
- D. Number of assurance meetings held

Question 26 (CISM8-083)

Scenario: A dashboard reports that supplier reviews are 90 percent complete, but it combines low-risk vendors with critical providers and does not show overdue age or unresolved findings.

Which reporting enhancement would MOST improve decisions?

- A. Segment reviews by criticality, age, findings, owner, and cause
- B. Add more colors to the dashboard.
- C. Report only the enterprise completion average.
- D. Exclude disputed findings until suppliers agree.

Question 27 (CISM8-084)

Scenario: A transport company cannot fund every maturity recommendation. Its lowest score affects a low-impact process, while a higher-scoring identity capability has recurring weaknesses affecting critical dispatch systems.

Which maturity investment approach is BEST?

- A. Fund only the lowest score.
- B. Raise every capability by one level.
- C. Prioritize maturity by risk, dependence, outcomes, affordability, and value
- D. Discard maturity information entirely.

Question 28 (CISM8-085)

Why should a control objective be defined before selecting a security control?

- A. It provides a basis for judging whether design alternatives address the intended risk and requirement.
- B. It guarantees the selected control will never fail.
- C. It makes control ownership unnecessary.
- D. It ensures the newest technology is chosen.

Question 29 (CISM8-086)

Scenario: Environmental inspectors work in remote areas with unreliable connectivity. A proposed control requires continuous online authorization and could prevent time-sensitive safety inspections.

Which control response is MOST appropriate?

- A. Deploy the control unchanged because maximum restriction is always safer.
- B. Remove all access controls from field devices.
- C. Assess access and safety needs, then design resilient offline safeguards, accountability, synchronization, and monitoring.
- D. Let inspectors disable controls without oversight.

Question 30 (CISM8-087)

Scenario: A company plans automated security configuration enforcement, but its service inventory is incomplete and ownership records are outdated.

Which design concern is MOST significant?

- A. The implementation team prefers another supplier.
- B. The control uses both preventive and detective features.
- C. The chosen tool has fewer dashboard layouts than competitors.
- D. Incomplete inventory and ownership can cause missed systems, inappropriate changes, and unresolved exceptions.

Question 31 (CISM8-088)

Scenario: A marketplace can block all unusual purchases automatically or combine risk-based blocking with rapid analyst review. The options differ in fraud reduction and legitimate customer disruption.

Which decision basis is BEST?

- A. Choose the option with the greatest number of rules.
- B. Compare coverage, false decisions, resilience, impact, maintainability, and cost
- C. Choose the lowest initial cost.
- D. Select the supplier's preferred design.

Question 32 (CISM8-089)

Scenario: A media company configures automated message deletion. Business owners have not validated retention rules, several repositories are excluded, and legal-hold exceptions are undefined.

Which retention-control conditions must be met before implementation is complete?

- A. The tool vendor confirms that deletion is enabled.
- B. Validate rules, procedures, readiness, and acceptance evidence
- C. Internal audit assumes responsibility for retention decisions.
- D. The project spends its remaining budget.

Question 33 (CISM8-090)

Scenario: A company reviews security only after customer-data migrations finish. Teams then discover excessive copies, incorrect access, and incomplete deletion of staging data.

Which project-lifecycle change would MOST improve outcomes?

- A. Perform a larger audit after each migration.
- B. Let migration vendors define all security requirements.
- C. Embed classification, access, transfer, validation, disposal, and acceptance requirements from planning through closure.
- D. Approve migrations automatically when deadlines are fixed.

Question 34 (CISM8-091)

Scenario: Sales teams bypass device registration because approvals are unavailable across time zones and replacement devices cannot be activated during travel emergencies.

Which device-registration adoption response is MOST appropriate?

- A. Declare success because the registration portal exists.
- B. Send additional reminders without changing availability.
- C. Remove device-registration requirements.
- D. Correct service-access barriers and manage interim risk

Question 35 (CISM8-092)

Scenario: A professional services firm pilots stricter email controls with headquarters staff. Field consultants use delegated mailboxes and mobile workflows that were not tested, and support teams lack procedures.

Which email-control deployment decision is BEST?

- A. Validate representative field workflows, delegated access, support, acceptance criteria, and rollback before phased expansion.
- B. Deploy to everyone because the headquarters pilot passed.
- C. Cancel the control because the pilot was incomplete.
- D. Let consultants decide whether the control applies.

Question 36 (CISM8-093)

Scenario: An automated process disables accounts after employment ends. Testing confirms that jobs run, but not that every worker source and application is included or that failures are resolved.

Which revised test is MOST appropriate?

- A. Review only job-completion logs.
- B. Test source and application completeness, timeliness, disablement results, exceptions, failed jobs, and remediation evidence.
- C. Confirm that the termination policy is approved.
- D. Rely on the operator's statement that automation works.

Question 37 (CISM8-094)

Scenario: Control reviews repeatedly lack evidence because operating teams store records in personal folders. Findings are closed after documents are manually collected, but the problem returns.

Which remediation response is MOST appropriate?

- A. Continue collecting missing evidence after each review.
- B. Correct the evidence-capture process, assign accountable owners, integrate retention into workflow, and track sustained performance.
- C. Close findings when operators promise to improve.
- D. Transfer control operation to the assurance team.

Question 38 (CISM8-095)

Which situation creates the GREATEST threat to assurance objectivity?

- A. An independent reviewer requests clarification from the operator.
- B. The control owner reviews operational metrics each month.
- C. The same manager operates the control, selects evidence, performs testing, and approves the effectiveness conclusion.
- D. Internal audit considers management testing when planning separate work.

Question 39 (CISM8-096)

Scenario: A warehouse meets a checklist requiring visitor logs. Reviews show missing escorts, inaccurate departure times, and active badges after visits end.

Which conclusion should the information security manager reach?

- A. Conformity evidence is insufficient; operating failures and resulting risk require remediation and reassessment.
- B. The checklist proves the control is effective.
- C. Residual risk is acceptable because logs exist.
- D. Further review should wait for a loss.

Question 40 (CISM8-097)

Why is role-based security training important?

- A. To make policy optional for specialized staff
- B. Build role-specific knowledge and risk-reducing behavior
- C. To transfer control ownership to every trainee
- D. To eliminate general awareness requirements

Question 41 (CISM8-098)

Scenario: Executives complete the same general awareness course as all employees but remain unclear about escalation thresholds, risk decisions, and program oversight duties.

Which executive-training response is MOST appropriate?

- A. Provide executive scenarios on governance decisions, thresholds, accountability, and program tradeoffs, then evaluate decision readiness.
- B. Measure success only through attendance.
- C. Repeat the general employee course more frequently.
- D. Transfer executive security decisions to technical staff.

Question 42 (CISM8-099)

Scenario: Employees increasingly report suspicious links, but remote sales staff continue sharing customer files through unapproved services when approved tools are slow.

Which awareness-program response should occur NEXT?

- A. Declare success based on link-reporting volume.
- B. Correct workflow barriers and measure sharing behavior
- C. Send the same additional course to everyone.
- D. Stop measuring behavior because indicators differ.

Question 43 (CISM8-100)

Scenario: An archive will use an external service to digitize sensitive historical records. Procurement has assessed price and quality but not access, evidence, incidents, subcontractors, retention, or deletion.

Which provider-governance package is MOST appropriate?

- A. Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, retention, return, deletion, and exit terms
- B. Transfer of record ownership to the provider
- C. Approval based solely on provider reputation
- D. A general confidentiality clause as the only safeguard

Question 44 (CISM8-101)

Scenario: A critical service provider is acquired and will move operations to a new shared platform. Existing assurance evidence, subcontractor lists, and continuity plans may no longer apply.

Which provider-change action should occur FIRST?

- A. Take operational control of the provider's new platform.
- B. Assume the original onboarding remains sufficient.
- C. Wait until the next routine annual review.
- D. Assess the change and require approved treatment for gaps

Question 45 (CISM8-102)

Scenario: A company is replacing an identity provider. User records can be exported, but credential transitions, application trust, administrator access, audit history, and deletion are not covered.

Which identity-provider exit plan is BEST?

- A. Terminate immediately and repair failed access later.
- B. Keep both providers active indefinitely.
- C. Test migration, continuity, revocation, evidence, deletion, and acceptance
- D. Rely on verbal confirmation that old accounts are protected.

Question 46 (CISM8-103)

Scenario: Service owners receive separate security reports with inconsistent definitions and no comparison to agreed risk thresholds or program objectives.

Which reporting improvement is MOST appropriate?

- A. Add all raw event records to every report.
- B. Let each reporting team define effectiveness independently.
- C. Show governed outcome trends, impacts, owners, actions, and decisions
- D. Remove unfavorable results until remediation closes.

Question 47 (CISM8-104)

Scenario: A temporary architecture exception has expired, migration has not started, and residual exposure now exceeds tolerance. The security manager cannot approve further acceptance.

Which escalation action is MOST appropriate?

- A. Extend the exception without approval.
- B. Accept the exposure on behalf of the business owner.
- C. Remove the item from reporting until migration begins.
- D. Escalate through the defined path with evidence, impact, ownership, treatment options, and the required decision.

Question 48 (CISM8-105)

Scenario: Business units bypass the security exception process because reviews take longer than project decisions and required approvers are unclear. Security designed the process alone.

Which engagement response would BEST improve the process?

- A. Require use of the existing process without review.
- B. Allow projects to self-approve all exceptions.
- C. Jointly define risk information, decision rights, service levels, escalation, review triggers, and success measures.
- D. Remove exception governance entirely.

Question 49 (CISM8-106)

Scenario: A company outsources development and operation of a customer product. Existing controls assume internal developers, internal release authority, and company-operated monitoring.

Which outsourcing-related program-maintenance action should occur FIRST?

- A. Apply internal procedures unchanged to the provider.
- B. Assess changed workflows, ownership, contracts, evidence, risks, and dependencies, then update controls, metrics, and the roadmap.
- C. Wait for service failures before updating controls.
- D. Treat the product as outside the security program.

Question 50 (CISM8-107)

Scenario: A farming enterprise wants autonomous vehicles to use field maps, operational networks, cloud analytics, and supplier maintenance access. Existing control coverage is unclear.

Which emerging-technology response is MOST appropriate?

- A. Let each farm create unrelated security rules.
- B. Permit unrestricted deployment until a failure occurs.
- C. Ban the technology permanently because standards do not name it.
- D. Set supplier guardrails, run a pilot, monitor outcomes, and update controls

Answer Key

Domain III - Information Security Program

1 C	2 C	3 A	4 D	5 D
6 B	7 B	8 D	9 C	10 A
11 B	12 D	13 A	14 D	15 D
16 A	17 A	18 B	19 B	20 A
21 C	22 B	23 D	24 A	25 C
26 A	27 C	28 A	29 C	30 D
31 B	32 B	33 C	34 D	35 A
36 B	37 B	38 C	39 A	40 B
41 A	42 B	43 A	44 D	45 C
46 C	47 D	48 C	49 B	50 D

Detailed Explanations

Question 1 (CISM8-058)

Correct answer: C - The leasing service's business outcomes, information, obligations, dependencies, and risks

Objectives should reflect the new service model, its information, obligations, dependencies, and exposure. Existing products and competitor controls are only inputs, while avoiding operational change may leave significant risk untreated.

Question 2 (CISM8-059)

Correct answer: C - An approved charter defining shared objectives, authority, scope, responsibilities, sponsorship, and escalation

A charter establishes the mandate and shared-accountability model needed across the cooperative. Configuration guidance and audits cannot create authority, while unrelated member objectives would fragment the program.

Question 3 (CISM8-060)

Correct answer: A - Reassess acquisition risks and dependencies, then propose a funded sequence aligned with integration milestones.

The acquisition changes both exposure and capability timing, so the roadmap should be risk-assessed and transparently resequenced. A fixed or unsupported plan is unrealistic, while deferring security leaves known integration risks.

Question 4 (CISM8-061)

Correct answer: D - Map the end-to-end journey, information flows, obligations, dependencies, risks, and responsibilities at every interface.

Scope should follow the complete business service and information risk, with accountability defined across organizational boundaries. Ownership and shared processing do not remove exposure, and providers cannot accept all airline accountability.

Question 5 (CISM8-062)

Correct answer: D - Control population, risk tiers, test frequency and method, evidence complexity, competencies, and automation

Testing capacity should reflect control scope, risk, frequency, method, evidence, competence, and automation. Current staffing, document length, and peer headcount do not establish this program's actual demand.

Question 6 (CISM8-063)

Correct answer: B - Use qualified localization support under internal control of objectives, accuracy review, behavior measures, and knowledge transfer.

External localization can add capacity while internal management retains risk direction, accuracy, and outcome ownership. Providers should not define objectives, untranslated content may fail locally, and indefinite delay leaves the need unmet.

Question 7 (CISM8-064)

Correct answer: B - A business case comparing risk reduction, operating benefits, migration dependencies, business impact, feasibility, and lifecycle cost

A decision-quality case connects expected benefits to migration dependencies, disruption, feasibility, and full cost. Features and supplier visibility are incomplete, while no identity program eliminates all access risk.

Question 8 (CISM8-065)

Correct answer: D - Create a competency plan combining targeted development, recruitment, succession, and selective external expertise.

A targeted competency plan addresses the specific capacity and knowledge needed through coordinated workforce options. Providers do not own enterprise risk, generic training is insufficient, and audit should not operate governance capabilities.

Question 9 (CISM8-066)

Correct answer: C - The accountable information owner

The information owner has business accountability for classification and handling needs. Administrators and providers act as custodians, while auditors assess rather than make ownership decisions.

Question 10 (CISM8-067)

Correct answer: A - Embedding ownership, classification, location, and lifecycle updates into application and business change processes

Inventory maintenance should accompany the processes that create and change information assets. Audit-only updates and hardware-only scope become incomplete, while security does not own every business asset.

Question 11 (CISM8-068)

Correct answer: B - Define classification-based review, redaction, approval, display, retention, and disposal rules within the presentation workflow.

Classification-based workflow rules make external use consistent and scalable across the information lifecycle. Removing labels hides sensitivity, central approval is impractical, and presentation counts do not demonstrate protection.

Question 12 (CISM8-069)

Correct answer: D - Confirm ownership and requirements before return, retention, and disposal

Ownership and applicable requirements must be established before defensible disposition. Immediate deletion and indefinite retention can both create risk, while administrators lack sole business authority.

Question 13 (CISM8-070)

Correct answer: A - To provide a structured basis for organizing, assessing, and improving relevant capabilities

A framework structures program capabilities and improvement when adapted to context. It does not transfer accountability, accept risk, or require universal technology choices.

Question 14 (CISM8-071)

Correct answer: D - Business objectives, risks, obligations, dependencies, and current capability gaps

Tailoring should align framework outcomes with the organization's objectives, risks, obligations, dependencies, and capabilities. Publication order, tool convenience, and consultant preference are not defensible priority bases.

Question 15 (CISM8-072)

Correct answer: D - Map requirements to a governed common control and evidence model while preserving customer-specific traceability.

A common control and evidence model reduces duplication while preserving distinct contractual accountability. Ignoring or assuming requirements are identical creates gaps, while separate implementations waste resources.

Question 16 (CISM8-073)

Correct answer: A - Policy

Policy states authoritative management direction and intent. Guidelines are advisory, procedures describe execution, and test plans define assurance work.

Question 17 (CISM8-074)

Correct answer: A - Procedure

A procedure defines the steps used to perform a task. Policy states direction, standards contain mandatory requirements, and guidelines provide recommendations.

Question 18 (CISM8-075)

Correct answer: B - Documented risk, accountable approval, compensating controls, monitoring, review triggers, and a defined expiration

A controlled exception must be risk-based, properly authorized, safeguarded, monitored, and time-limited. Permanent exclusion and operator approval bypass governance, while incident history does not establish acceptable future exposure.

Question 19 (CISM8-076)

Correct answer: B - Engage accountable owners to determine applicable requirements, then approve and communicate a consistent retention rule.

The conflict requires an authorized decision grounded in business and legal requirements and reflected consistently in documents. Local choice creates inconsistency, longer retention can increase risk, and waiting leaves operations without valid direction.

Question 20 (CISM8-077)

Correct answer: A - Security principles and shared capabilities aligned with the target enterprise architecture, business needs, and risks

Aligned principles and shared capabilities create consistent direction for the composable model. Product uniformity and configuration detail do not alone ensure alignment, while unrelated designs preserve fragmentation.

Question 21 (CISM8-078)

Correct answer: C - A gap and dependency analysis defining transition states, interim controls, accountable owners, and milestones

A transition analysis makes the target achievable while governing dependencies and temporary exposure. A target diagram alone is incomplete, immediate replacement may be unsafe, and permanent separate targets defeat convergence.

Question 22 (CISM8-079)

Correct answer: B - Traceability from the separation requirement to data flows, architecture decisions, control ownership, and acceptance criteria

Traceability demonstrates how the business requirement drives design and verifiable controls across shared services. Device lists and industry popularity do not establish separation, and the organization retains architecture governance.

Question 23 (CISM8-080)

Correct answer: D - Assess the deviation, approve interim controls, and track convergence

A governed transition can accommodate a legitimate constraint while managing risk and preserving convergence. Absolute rejection may be impractical, exclusion abandons oversight, and suppliers do not own enterprise risk acceptance.

Question 24 (CISM8-081)

Correct answer: A - Compare risk reduction, resilience, dependencies, interim controls, operational impact, support capacity, lifecycle cost, and exit criteria.

The roadmap choice should balance target benefits with transition risk, resilience, dependencies, support, and cost. Speed alone is insufficient, indefinite delay preserves gaps, and unrelated targets perpetuate fragmentation.

Question 25 (CISM8-082)

Correct answer: C - Timely sustainable remediation of material deficiencies

Validated risk, ownership, and timely sustainable remediation show whether assurance drives meaningful improvement. Templates, evidence hours, and meetings measure activity rather than the outcome.

Question 26 (CISM8-083)

Correct answer: A - Segment reviews by criticality, age, findings, owner, and cause

Risk, age, findings, ownership, and cause reveal material exposure hidden by the average and support targeted action. Presentation changes and aggregate completion do not provide that context, while excluding findings weakens transparency.

Question 27 (CISM8-084)

Correct answer: C - Prioritize maturity by risk, dependence, outcomes, affordability, and value

Maturity decisions should combine scores with risk, criticality, outcomes, dependencies, and value. Score-only and uniform investment ignore impact, while maturity remains a useful contextual input.

Question 28 (CISM8-085)

Correct answer: A - It provides a basis for judging whether design alternatives address the intended risk and requirement.

A clear objective allows alternatives to be evaluated against the required risk-reducing result. It does not guarantee operation, remove ownership, or dictate technology based on novelty.

Question 29 (CISM8-086)

Correct answer: C - Assess access and safety needs, then design resilient offline safeguards, accountability, synchronization, and monitoring.

The control should reduce access risk while supporting predictable field conditions through governed offline operation. Inflexible restriction can create safety risk, while removing or individually disabling controls abandons accountability.

Question 30 (CISM8-087)

Correct answer: D - Incomplete inventory and ownership can cause missed systems, inappropriate changes, and unresolved exceptions.

Reliable scope and ownership are essential design dependencies for complete, accountable enforcement. Layered features, dashboard preferences, and team preference do not address that fundamental risk.

Question 31 (CISM8-088)

Correct answer: B - Compare coverage, false decisions, resilience, impact, maintainability, and cost

The strategy should balance effective fraud reduction with error consequences, response capacity, resilience, customer impact, and cost. Rule count, supplier preference, and initial price alone are insufficient.

Question 32 (CISM8-089)

Correct answer: B - Validate rules, procedures, readiness, and acceptance evidence

Implementation requires validated requirements, complete scope, procedures, competence, and acceptance evidence. Tool activation and spending are insufficient, while internal audit should not own business retention decisions.

Question 33 (CISM8-090)

Correct answer: C - Embed classification, access, transfer, validation, disposal, and acceptance requirements from planning through closure.

Lifecycle integration lets data protection and closure requirements shape migration before copies and access proliferate. Post-migration review is late, vendors do not own requirements, and deadlines do not justify automatic approval.

Question 34 (CISM8-091)

Correct answer: D - Correct service-access barriers and manage interim risk

The program should correct approval and emergency-process barriers while governing interim exposure. Portal availability and reminders do not fix them, while removing registration abandons the control objective.

Question 35 (CISM8-092)

Correct answer: A - Validate representative field workflows, delegated access, support, acceptance criteria, and rollback before phased expansion.

A phased rollout should extend evidence to field workflows and confirm support and recovery readiness. Headquarters results cannot simply be generalized, cancellation discards a viable control, and individual choice weakens governance.

Question 36 (CISM8-093)

Correct answer: B - Test source and application completeness, timeliness, disablement results, exceptions, failed jobs, and remediation evidence.

The test must establish complete coverage, timely results, and effective exception and failure handling. Job logs, policy approval, and operator assertions do not demonstrate the full control objective.

Question 37 (CISM8-094)

Correct answer: B - Correct the evidence-capture process, assign accountable owners, integrate retention into workflow, and track sustained performance.

The recurring issue requires root-cause correction of the evidence process and accountable outcome tracking. Repeated manual collection and promises do not create sustainability, while assurance should not operate the control.

Question 38 (CISM8-095)

Correct answer: C - The same manager operates the control, selects evidence, performs testing, and approves the effectiveness conclusion.

Combining operation, evidence selection, testing, and final approval creates a direct self-review threat. Owner monitoring is expected, reviewers may request clarification, and audit may consider management work while retaining independent judgment.

Question 39 (CISM8-096)

Correct answer: A - Conformity evidence is insufficient; operating failures and resulting risk require remediation and reassessment.

Checklist conformity does not override direct evidence of operating failure or determine risk acceptance. Logs alone are insufficient, and waiting for a loss would abandon proactive assurance.

Question 40 (CISM8-097)

Correct answer: B - Build role-specific knowledge and risk-reducing behavior

Role-based training prepares people for specific decisions and responsibilities in their work. It does not make policy optional, transfer ownership automatically, or remove the value of baseline awareness.

Question 41 (CISM8-098)

Correct answer: A - Provide executive scenarios on governance decisions, thresholds, accountability, and program tradeoffs, then evaluate decision readiness.

Executive training should address the governance judgments leaders actually make and assess readiness for those decisions. Generic repetition and attendance are indirect, while decision authority should not be transferred to technical staff.

Question 42 (CISM8-099)

Correct answer: B - Correct workflow barriers and measure sharing behavior

The segmented behavior suggests both workflow and awareness barriers requiring targeted correction and measurement. Reporting volume does not negate the gap, while stopping measurement or generic training will not address its cause.

Question 43 (CISM8-100)

Correct answer: A - Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, retention, return, deletion, and exit terms

The service requires lifecycle governance proportionate to the records' sensitivity. A clause and reputation are insufficient, while the archive retains information ownership and accountability.

Question 44 (CISM8-101)

Correct answer: D - Assess the change and require approved treatment for gaps

The acquisition and platform move are material changes requiring timely reassessment and use of contractual governance. Original evidence may no longer apply, annual review is too late, and the customer should oversee rather than operate the provider.

Question 45 (CISM8-102)

Correct answer: C - Test migration, continuity, revocation, evidence, deletion, and acceptance

A complete exit must preserve authentication continuity and evidence while ending old trust and access and verifying deletion. Immediate termination can disrupt services, indefinite coexistence increases exposure, and verbal assurance is weak evidence.

Question 46 (CISM8-103)

Correct answer: C - Show governed outcome trends, impacts, owners, actions, and decisions

Consistent, outcome-oriented reporting enables comparison and decision-making tied to risk and ownership. Independent definitions prevent coherence, raw records obscure significance, and hiding results undermines oversight.

Question 47 (CISM8-104)

Correct answer: D - Escalate through the defined path with evidence, impact, ownership, treatment options, and the required decision.

Expired authority and exposure above tolerance require transparent escalation to the proper decision body. Unapproved extension, omission, and acceptance by the security manager bypass accountable governance.

Question 48 (CISM8-105)

Correct answer: C - Jointly define risk information, decision rights, service levels, escalation, review triggers, and success measures.

Joint redesign can make the process timely and clear while preserving accountable risk decisions and oversight. Forced use without correction sustains bypass, self-approval weakens governance, and removing the process abandons control.

Question 49 (CISM8-106)

Correct answer: B - Assess changed workflows, ownership, contracts, evidence, risks, and dependencies, then update controls, metrics, and the roadmap.

Outsourcing changes control operation, accountability, evidence, and dependencies, requiring a structured program update. Unchanged internal procedures may not fit, exclusion abandons governance, and waiting is reactive.

Question 50 (CISM8-107)

Correct answer: D - Set supplier guardrails, run a pilot, monitor outcomes, and update controls

Governed experimentation supports business learning while addressing safety, data, network, and supplier risks and feeding evidence into program improvement. Unrestricted use lacks safeguards, a permanent ban avoids proportionate assessment, and local rules fragment governance.